

INTERNATIONAL CYBERSECURITY AND
DIGITAL FORENSICS ACADEMY

GRC102: INFORMATION SECURITY GOVERNANCE

WEEK 1 PRACTICAL LABORATORY

Information Security Governance in Action

Student detail	Information
Student name	Adediran Eunice Adebukola
Registration number	C11-26-CGRCE-17 595
Scenario	GlobalHealth Connect (GHC)
Submission date	11 September 2026

Prepared as a confidential governance simulation report for executive review.

Executive Overview

GlobalHealth Connect has outgrown an informal security model centred on IT operations. Two acquisitions, inconsistent policies and a contained data-leakage near-miss show that the organisation now needs clear authority, shared accountability and reliable oversight. This report establishes a governance blueprint, an Information Security Charter, Board metrics, a Security Steering Committee and a 12–18 month maturity roadmap. The design supports GHC’s 2026 goals by protecting patient information while enabling regional growth, operational efficiency and responsible innovation.

The immediate posture is Red. Phishing reports, malware detections and high-risk incidents have all risen for six consecutive months, while the proportion of critical vulnerabilities patched has fallen from 67% to 55%. Training completion improved from 45% to 70%, but the remaining gap and worsening outcome measures show that awareness activity has not yet controlled exposure. The recommended response is disciplined governance: named business risk owners, Board-approved appetite, verified remediation, stronger identity controls, cross-functional decisions and evidence-based reporting.

Task 1 — Governance Blueprint

1.1 Current-State Governance Gap Assessment

Gap	Evidence and consequence	Priority response
Security authority is informal	The IT Manager performs some security work, but no independent governance mandate or enterprise risk owner is identified. Decisions may be driven by technical urgency rather than patient, regulatory and business impact.	Appoint a Director/CISO with direct executive and Board access; assign business risk ownership.
No cross-functional decision body	IT, development, compliance, finance and HR affect security but lack a forum for joint prioritisation. Acquisition issues and policy conflicts can remain unresolved.	Create a Security Steering Committee (SSC) with delegated authority and documented decisions.
Policies are inconsistent and outdated	Inherited policies vary across acquired entities. Staff cannot know which requirement is authoritative, and evidence may not support regulatory scrutiny.	Create one controlled policy framework, ownership register, review cycle and exception process.
Risk management is reactive	The near-miss and interview summary show response after events rather than a repeatable identification, assessment and treatment process.	Adopt a common risk method, register, appetite thresholds and monthly treatment review.
Board information is not decision-useful	Technical measures exist but are not consistently translated into service, patient, financial or compliance impact.	Provide a concise quarterly dashboard with trends, outside-appetite risks and decisions required.
Control assurance is weak	Falling patch performance and increasing incidents suggest that activity is not being verified for effectiveness.	Require control testing, evidence-based closure and independent assurance.
Acquisition and third-party governance is immature	Different inherited practices and cloud dependencies can create unknown exposure across the service chain.	Include security due diligence, integration plans, contract requirements and supplier monitoring.

1.2 Proposed Governance Organisation

Oversight layer	Primary roles / relationship	Core responsibility
Board of Directors / Board Risk Committee	Receives independent reporting from the Director of Information Security Governance and assurance from Internal Audit.	Approve risk appetite, Charter and major investment; oversee material risk and incidents.
CEO and Executive Committee	CEO sponsors governance; CFO, CTO and other executives own enterprise decisions.	Allocate resources, accept material risk within authority and hold leaders accountable.
Security Steering Committee	CEO sponsor; Director/CISO chair; CTO, CFO, Compliance, IT, HR, Product, Privacy and regional representation.	Prioritise risks, approve standards, resolve conflicts and monitor remediation.
Director of Information Security Governance / CISO	Administrative line to CEO; direct access to Board Risk Committee; coordinates with CTO without being subordinated to delivery.	Maintain strategy, policy, risk view, reporting, incident governance and challenge.
Operational and business owners	IT Manager, developers, Compliance Officer, HR, Finance, product and service owners.	Operate controls, own risks in their processes, preserve evidence and escalate exceptions.
Internal Audit	Independent of management; reports assurance to the Board.	Test governance and control effectiveness and follow up findings.

1.3 RACI Matrix

Governance activity	Board	CEO	CISO	SSC	CTO / IT	Compliance	Business owner	Audit
Approve Security Charter / policy	A	C	R	C	C	C	I	I
Set cyber risk appetite	A	R	C	C	C	C	I	I
Review enterprise security risks	I	A	R	C	C	C	R	I
Approve material risk exception	A*	R	C	C	C	C	R	I
Incident response planning	I	A	R	C	R	C	C	I
Critical vulnerability remediation	I	A	C	I	R	C	R	I
Quarterly Board reporting	I	A	R	C	C	C	I	C
Independent assurance	I	I	C	I	C	C	I	R/A

*Board approval applies where the exception exceeds executive authority or approved risk appetite. R = Responsible, A = Accountable, C = Consulted, I = Informed.

This structure creates accountability by distinguishing oversight, risk ownership, control operation and independent assurance. Transparency comes from recorded decisions, risk registers, exception expiry dates and direct Board reporting. Business alignment is maintained because executives and service owners decide how risk affects growth, trust, uptime and innovation. Risk management becomes continuous: risks are assessed, treated, monitored and escalated instead of being handled only after an incident.

Task 2 — GHC Information Security Charter

2.1 Information Security Charter

Charter section	Approved statement
Purpose	The Information Security Programme protects the confidentiality, integrity and availability of GHC information and services. It supports safe growth, reliable patient-management services, regulatory excellence, operational efficiency and responsible innovation.
Scope	All GHC employees, contractors, acquired entities, locations, cloud services, applications, infrastructure, patient and business information, development activities, physical records and third parties that create, access, process, store or transmit GHC information.
Authority	The Charter is authorised by the Board and sponsored by the CEO. The Director/CISO may define mandatory security standards, require evidence, investigate events, convene incident governance, stop or escalate activity presenting imminent material risk, and report directly to the Board Risk Committee.
Roles and responsibilities	The Board oversees risk and approves appetite. The CEO ensures resources and accountability. The SSC directs priorities. The CISO maintains the programme. Executives and business owners own risk. CTO/IT and other control owners implement controls. Compliance interprets obligations. Internal Audit provides independent assurance.
Key principles	Security is risk-based, business-aligned, proportionate to information and service criticality, designed into change, shared across the organisation, evidence-led and continuously improved. Patient safety, privacy and trust receive priority.
Reporting	Material incidents and outside-appetite risks are escalated immediately. The SSC receives monthly reporting. The Executive Committee receives at least monthly summaries. The Board Risk Committee receives a quarterly dashboard and prompt notice of material events or decisions.
Review and approval	The Board approves this Charter. The CISO reviews it annually and after major acquisition, legal change, material incident or strategic change. Revisions follow document control, consultation through the SSC and approval at the appropriate authority level.

2.2 Memorandum to the CFO

To: Marcus Thorne, Chief Financial Officer
 From: Director of Information Security Governance
 Subject: Business case for approving the GHC Information Security Charter

The Charter turns security expenditure into governed business investment. It links authority and accountability to GHC's goals: protecting patient trust, entering two regional markets, improving uptime and introducing AI-enabled services. Clear decision rights reduce duplicated acquisition controls and prevent unresolved risks from being passed between IT, product and compliance. A defined escalation route also gives management earlier visibility of risks that may require funding, insurance, contract change or launch decisions.

For investment decisions, the Charter requires proposals to identify risk reduction, service dependency, regulatory need, accountable owner and measurable outcome. This allows the CFO and SSC to compare spending options on a common basis rather than approving isolated technology purchases. Quarterly reporting will show whether approved investment reduces outside-appetite exposure, improves patching and resilience, and protects the 10% efficiency objective from avoidable incident cost.

Task 3 — Board Reporting and Security Metrics

3.1 One-Page Board Executive Summary

OVERALL POSTURE			RED	
The Red rating reflects a worsening combination of threat volume, control performance and incident outcome. From September to February, phishing reports rose from 150 to 320, malware detections doubled, critical-vulnerability patching declined by 12 percentage points, and high-risk incidents rose from 2 to 7. Training completion improved by 25 percentage points, but 30% of staff remain incomplete and the adverse trends have not stabilised. Patient trust, 99.99% availability and planned market entry are therefore exposed.				
Board metric	Current status (Feb.)	Six-month trend	RAG	Business interpretation
High-risk incidents	7	2 → 7 (+250%)	Red	Direct evidence of worsening impact and a growing chance of patient, service or regulatory harm.
Critical vulnerability patching	22 of 40 (55%)	67% → 55% (−12 points)	Red	18 critical items remain open; exploitation could interrupt services or expose sensitive data.
Phishing reports	320	150 → 320 (+113%)	Red	Rapid growth in attempted social engineering increases account compromise and fraud exposure.
Malware detections	50	25 → 50 (+100%)	Red	Rising detections suggest greater endpoint pressure and possible control or behaviour weaknesses.
Training completion	70%	45% → 70% (+25 points)	Amber	Improvement is positive, but incomplete coverage remains material and must be linked to behaviour.

Priority risks and recommended decisions

Priority risk / issue	Board action requested
Unpatched critical vulnerabilities could be exploited against patient-management services and undermine the 99.99% uptime goal.	Approve a 30-day critical-remediation recovery plan, weekly executive tracking, compensating controls and explicit exceptions.
Increasing phishing, malware and high-risk incidents could lead to credential compromise, data leakage and loss of customer trust.	Fund phishing-resistant MFA, managed password tools, targeted simulations and enhanced monitoring; require monthly outcome reporting.
Acquisition policy inconsistency creates uneven controls and weak evidence for regional expansion.	Approve the Charter, SSC and a six-month policy harmonisation programme.

3.2 Metric-Selection Rationale

These five metrics give the Board a balanced view of threat pressure, control performance, workforce readiness and realised risk. Phishing and malware indicate external and endpoint pressure; patching and training show whether two important preventive controls are operating; high-risk incidents show outcome. Each metric has a six-month trend and a clear link to patient trust, service availability, compliance or investment. Operational detail such as raw firewall alerts is excluded unless it changes a material risk or decision.

Task 4 — Security Steering Committee

4.1 Terms of Reference

Element	Terms
Purpose	Provide cross-functional direction, prioritisation and oversight for information security so that risk decisions support GHC strategy.
Scope	Enterprise security risks; policy and standards; major exceptions; incidents; acquisitions; suppliers; resilience; regulatory readiness; metrics; material technology and product change.
Membership	Chair: Director/CISO. Executive sponsor: CEO. Standing members: CFO, CTO, Compliance Officer, IT Manager, HR, Product/Operations, Privacy/Legal and regional/acquisition representatives. Internal Audit attends as independent observer.
Responsibilities	Review risks and trends; approve standards within delegation; prioritise treatment and investment; resolve conflicts; monitor overdue actions; sponsor culture; escalate outside-appetite risk.
Cadence and quorum	Monthly and additionally for urgent decisions. Quorum is Chair plus four members, including one business executive, Technology and Compliance/Privacy. Papers circulate three working days before meetings.
Decision authority	Consensus is preferred. The Chair records decisions and dissent. The CEO decides unresolved executive matters. Risks above appetite, material incidents and major unfunded exposure escalate to the Board Risk Committee.
Reporting and records	A decision log, action tracker, risk changes and exceptions are retained. Monthly minutes go to the Executive Committee; quarterly themes and decisions go to the Board.

4.2 First Meeting Agenda

Time	Agenda item	Desired outcome
00:00–00:05	Welcome, conflicts of interest and approval of Terms of Reference	Committee constituted and quorum confirmed.
00:05–00:15	Near-miss overview and immediate lessons	Agree urgent owners and escalation.
00:15–00:30	Six-month risk and metric dashboard	Confirm Red posture and priority decisions.
00:30–00:50	Password-policy conflict	Replace the proposed 30-day reset model with an evidence-based standard: long passwords/passphrases, compromised-password screening, MFA, approved password manager, rate limiting and change after compromise.
00:50–01:00	Critical-vulnerability recovery plan	Approve targets, resources, compensating controls and reporting.
01:00–01:10	Charter, policy harmonisation and acquisition integration	Recommend approvals and owners.
01:10–01:15	Actions, decisions, escalations and next meeting	Confirm accountable owners and dates.

4.3 Briefing Note to the CEO

The SSC gives the password disagreement a transparent route to decision. The CTO's productivity concern and the IT Manager's security concern are both legitimate inputs, but neither function decides alone. The committee will assess threat, user behaviour, operational cost and available safeguards, then record an accountable decision against risk appetite. NIST guidance supports password managers and does not favour routine password changes without evidence of compromise; therefore, the proposed 16-character password changed every 30 days should be revised rather than accepted as written (NIST, 2025).

The balanced standard will require a strong minimum password length, screening against common or compromised passwords, MFA—preferably phishing-resistant for privileged and sensitive access—approved password-manager integration, login throttling, monitoring and immediate reset when compromise is suspected. This improves real protection while reducing predictable passwords and user workarounds. The same evidence-based approach will allow the SSC to settle future conflicts without losing strategic alignment or executive accountability.

Task 5 — Governance Maturity Assessment

5.1 Current Maturity

Domain	Current level	Evidence and judgement	Target
Policy & Documentation	2 — Initial	Policies exist but are inconsistent, inherited and not always current.	3 — Defined
Roles & Responsibilities	1 — Ad Hoc	Ownership and accountability are unclear; security is dispersed informally.	3 — Defined
Risk Management	1 — Ad Hoc	Response is reactive and there is no formal proactive assessment process.	3 — Defined
Metrics & Reporting	2 — Initial	Technical measures exist, but business interpretation and consistent reporting are weak.	3 — Defined
Training & Awareness	2 — Initial	Training is mandatory and completion is improving, but participation remains incomplete and effectiveness is unclear.	3 — Defined
Compliance	2 — Initial	Activity is driven by audits rather than continuous obligations and evidence monitoring.	3 — Defined

5.2 12–18 Month Roadmap

Initiative / timing	Objective	Key activities	Measurable outcome
1. Establish governance (Months 0–3)	Create authority and accountability.	Approve Charter and appetite; appoint CISO; launch SSC; assign risk/control owners; implement escalation and exception logs.	100% of top risks have accountable owners; monthly SSC and quarterly Board reporting operating.
2. Harmonise policy and risk (Months 2–6)	Reach one defined control baseline across acquisitions.	Inventory policies and obligations; approve hierarchy; conduct enterprise risk assessment; consolidate risk register; control document changes.	All six domains documented; 100% policies have owners/review dates; material risks assessed.
3. Stabilise priority controls (Months 2–9)	Reduce immediate patient-data and service exposure.	Critical-patch recovery; MFA; password manager; access reviews; logging; incident exercises; supplier prioritisation.	Critical patching ≥95%; zero critical item beyond SLA without approved exception; two exercises completed.
4. Build culture and reporting (Months 4–12)	Turn awareness and metrics into behaviour and decisions.	Role-based training; phishing simulations; Board dashboard; quality checks; measure repeat failures and reporting rates.	Training ≥95%; repeat simulation failure declining; five Board metrics reported consistently for two quarters.
5. Assure and improve (Months 9–18)	Demonstrate Level 3 operation and move selected areas toward Level 4.	Control self-assessment; compliance monitoring; internal audit; management review; corrective-action retesting; post-acquisition reviews.	All domains assessed at Level 3; ≥90% actions closed on time; no major repeat finding.

5.3 Executive Summary to the Board

GHC is currently between Ad Hoc and Initial maturity. Policies and training exist, but roles and risk management remain largely reactive, and available metrics are not consistently converted into business decisions. This is not adequate for an organisation handling sensitive health information while integrating acquisitions and entering new markets. The maturity gap increases the likelihood that control weaknesses remain unknown, unowned or unresolved until they become incidents.

The roadmap aims for Level 3 across all six domains within 12–18 months. The sequence first establishes authority and risk ownership, then harmonises policies and addresses urgent control exposure, followed by culture, reporting and independent assurance. Success will be measured through outcomes such as at least 95% critical-patch compliance, complete ownership

of material risks, at least 95% training completion, timely corrective action and two consecutive quarters of reliable Board reporting. NIST CSF 2.0 supports this emphasis by placing governance—including roles, policy, risk strategy and oversight—at the centre of cybersecurity risk management (NIST, 2024).

Conclusion

GHC's near-miss should be treated as an early warning. The organisation does not need more isolated security activity; it needs a system that converts risk into accountable decisions. The proposed Charter, governance structure, RACI model, Board dashboard, SSC and maturity roadmap form that system. They allow GHC to protect patient trust and service availability while controlling the risks created by growth, acquisitions and innovation. Progress should be judged through verified reduction of exposure and reliable evidence, not simply by the number of policies or tools introduced.

References

- International Organization for Standardization. (2022). ISO/IEC 27 001:2022—Information security, cybersecurity and privacy protection—Information security management systems—Requirements. <https://www.iso.org/standard/27001>
- National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29). <https://doi.org/10.6028/NIST.CSWP.29>
- National Institute of Standards and Technology. (2025). Digital identity guidelines: Authentication and authenticator management (NIST SP 800-63B-4). <https://pages.nist.gov/800-63-4/sp800-63b.html>

Submission Note

GitHub profile supplied by the student: <https://github.com/Eunice2000>. No repository or command-line evidence is required by this laboratory brief; the assessed evidence is contained in this written report.

Before submission, the student should read the report, confirm that the analysis reflects their judgement and course material, and complete the E-Campus responsible AI-use declaration truthfully.